

Ghulam Ishaq Khan Institute of Engineering Sciences and Technology



Project: Secure QR-Based Attendance System

Course: Secure Software Design (CY-321)

Risk Management Document

Group Members

Zulqarnain Umar	2023556
Awais Khan	2023139
Moawiz-Ur-Rehman	2023278

1. INTRODUCTION TO RISK MANAGEMENT

All software systems inherently carry risks. Without proper risk management, minor issues can escalate into major failures affecting reliability, trust, and project success. For our Secure QR-Based Attendance System, we must systematically identify, assess, and address potential risks to ensure delivery of a secure and dependable solution.

1.1 Risk Handling Approaches

Approach	Description	Our Application
Avoid	Eliminate the risk by discontinuing or redesigning features	We will avoid QR code downloads that could be shared
Mitigate	Implement controls to reduce risk likelihood or impact	Primary approach for most security risks
Accept	Acknowledge and tolerate residual risk	For low-impact, low-likelihood scenarios
Transfer	Shift liability to another party	Through disclaimers and university policies
Ignore	Take no action (highly ill-advised)	Not applicable - we address all identified risks

2. RISK IDENTIFICATION AND CATEGORIZATION

2.1 Risk Categories

Category	Description
Technical Risks	Technology, implementation, and architecture-related issues
Security Risks	Threats compromising confidentiality, integrity, or availability

Category	Description
Project Risks	Timeline, resources, and delivery challenges
Operational Risks	Deployment, user adoption, and maintenance concerns

2.2 Risk Register

ID	Risk Description	Category	Likelihood (1-5)	Impact (1-5)	Score	Priority
R01	QR code replay attacks (screenshot sharing)	Security	4	5	20	CRITICAL
R02	Authentication bypass / unauthorized access	Security	3	5	15	HIGH
R03	Token manipulation / QR data tampering	Security	3	4	12	HIGH
R04	Database breach / data theft	Security	2	5	10	HIGH
R05	Server downtime / unavailability	Technical	3	4	12	HIGH
R06	Session hijacking	Security	2	4	8	MEDIUM

ID	Risk Description	Category	Likelihood (1-5)	Impact (1-5)	Score	Priority
R07	Time synchronization issues	Technical	3	3	9	MEDIUM
R08	Integration failure with university auth system	Technical	3	4	12	HIGH
R09	Poor user adoption	Operational	3	4	12	HIGH
R10	Brute force attacks on tokens	Security	2	3	6	LOW
R11	Man-in-the-middle attacks	Security	2	5	10	HIGH
R12	Insufficient testing coverage	Project	2	4	8	MEDIUM
R13	Data privacy compliance issues	Operational	2	4	8	MEDIUM
R14	QR scanning failures (hardware/display)	Technical	2	2	4	LOW

Risk Scoring Matrix:

- 1-4: Low Risk
- 5-9: Medium Risk

- 10-15: High Risk
- 16-25: Critical Risk

3. BUSINESS CONTEXT AND STAKEHOLDER ANALYSIS

3.1 Stakeholder Goals

Stakeholder	Primary Goals
University Administration	Accurate attendance records, audit trails, compliance
Teachers	Time-efficient process, reliability, ease of use
Students	Fair marking, simple process, transparency
Parents	Child's regular attendance, trust in system
Regulatory Bodies	Data protection, privacy compliance

3.2 Business Goals

1. Accuracy - No false attendance marking
2. Security - Prevention of proxy attendance and fraud
3. Efficiency - Minimal class time used
4. Transparency - Clear records accessible to all
5. Compliance - Meeting data protection requirements

4. RISK MITIGATION STRATEGIES

4.1 Critical and High Priority Risks

Risk ID	Mitigation Strategy	Responsible	Verification Method
R01: QR Replay	• One-time random nonce in each QR • 60-second token expiry • Server-side nonce tracking • Timestamp validation	Backend Developer	Simulate screenshot reuse; verify rejection
R02: Auth Bypass	• University SSO integration • Role-based access control • Session management with timeouts	Security Lead	Attempt unauthorized access; verify blocks
R03: Token Manipulation	• Cryptographic signing of QR data • Server-side signature verification • Strict input validation	Backend Developer	Test modified QR codes; verify rejection
R04: Database Breach	• Encryption of sensitive data at rest • Parameterized queries (SQL injection prevention) • Principle of least privilege • Regular encrypted backups	DBA	Vulnerability scanning; penetration testing
R05: Server Downtime	• Redundant server configuration • Automated health checks • 99.5% uptime target	DevOps	Load testing; failover testing

Risk ID	Mitigation Strategy	Responsible	Verification Method
	• Documented recovery procedure		
R08: Auth Integration	• Early integration testing with mock APIs • Fallback mechanism for development • Thorough documentation	Integration Lead	Unit tests; integration tests
R09: User Adoption	• Involve users in testing phase • Intuitive UI design • Training materials and guides • Feedback collection	UI/UX Lead	User acceptance testing; surveys
R11: MITM Attacks	• Enforce HTTPS with TLS 1.3 • Valid SSL certificates • HSTS implementation	Security Lead	Network security scan

4.2 Medium Priority Risks

Risk ID	Mitigation Strategy
R06: Session Hijacking	Secure HTTP-only cookies; session timeout; IP binding (optional)
R07: Time Sync Issues	Server time as source of truth; accept ± 2 minute drift; NTP synchronization

Risk ID	Mitigation Strategy
R12: Insufficient Testing	Automated testing; defined test cases; peer reviews; dedicated testing phase
R13: Privacy Compliance	Follow data protection regulations; anonymize data; clear privacy policy

4.3 Low Priority Risks

Risk ID	Mitigation Strategy
R10: Brute Force	Rate limiting; account lockout after 5 failures; CAPTCHA for repeated attempts
R14: Scanning Failures	Support manual entry fallback; optimize QR contrast; test multiple devices

5. RISK HANDLING SUMMARY

Priority	Number of Risks	Handling Strategy	Resource Allocation
CRITICAL	1	Avoid/Mitigate - Strongest technical controls	40% of security effort
HIGH	7	Mitigate - Robust controls with monitoring	40% of security effort
MEDIUM	4	Accept/Monitor - Basic controls, regular review	15% of security effort
LOW	2	Accept - Document and observe	5% of security effort

6. SECURITY STANDARDS ALIGNMENT

Our risk management approach aligns with industry standards:

Standard	Application
OWASP Development Guide	Secure coding practices for web applications
OWASP Testing Guide	Comprehensive security testing methodology
NIST SP 800-30	Risk assessment and management framework
ISO/IEC 27001	Information security management principles
PCI DSS (relevant principles)	Secure system development; access monitoring; regular testing

7. RESIDUAL RISK ASSESSMENT

After implementing all mitigation strategies, the following residual risks remain:

Risk Area	Residual Level	Rationale	Acceptance
QR Replay	Very Low	Nonce + short expiry window makes successful attack extremely difficult	Accepted
Database Breach	Low	Encryption protects data even if breached	Accepted
Server Downtime	Low	Redundancy reduces but cannot eliminate all downtime	Accepted

Risk Area	Residual Level	Rationale	Acceptance
Zero-day Vulnerabilities	Medium	Cannot predict unknown exploits; rely on monitoring and updates	Accepted with monitoring
User Error	Low	Clear interface and instructions minimize mistakes	Accepted

8. RISK MONITORING PLAN

Activity	Frequency	Responsible Party
Risk Register Review	Weekly	Project Manager
Security Code Review	Per sprint	Development Team
Vulnerability Scanning	Monthly	Security Lead
Penetration Testing	Pre-release	Security Team
User Feedback Analysis	Continuous	Support Team
Incident Response Drills	Quarterly	Entire Team